

Take-Home Assignment 2: A Scoped Web Application Engagement

Capstone — Applying Labs 5 and 6 Together

Course: Hands-On Ethical Hacking and Network Defense, 4e — Module 1 companion assignment **Format:** Individual, completed outside class, in your own lab environment **Estimated time:** 2-2.5 hours **Prerequisite:** Labs 5 and 6 completed. **Due:** (instructor to fill in)

The Scenario

(A new client, distinct from Lab 6's Harrow scenario — read it once.)

Bellwood Municipal Library wants a “quick security check” of their new online catalog and account portal before it goes live system-wide. The library's director emails: *“Our vendor built this on an open-source stack similar to what's demoed in class — go ahead and poke at the demo instance we set up, it's basically the real thing. We don't have a lot of budget so let's keep this informal, and just let us know what you find. One of our board members used to do IT so he can sign off.”*

The “demo instance” they mean is your own OWASP BWA VM, standing in for the library's real system for this assignment.

Part 1 — Do the Paperwork First (Lab 6 skills)

Before you open Burp Suite, treat this exactly like Lab 6:

1. Run the Four Gates against this request as written. Identify what's missing.
2. Find at least three red flags in the director's email, using the Rules of Engagement checklist categories.
3. Draft a corrected Rules of Engagement covering all six categories, as it should read once the gaps are fixed.
4. Draft the authorization letter (all five elements) that you would actually want signed before touching anything — including who specifically should sign it, given what the email says about the board member.
5. State which engagement type and testing model this request actually calls for, and defend your choice the way Part G of Lab 6 asked you to.

You may not skip to Part 2 without finishing this section. The point of this assignment is that the paperwork constrains the technical work that follows — not the other way around.

Part 2 — Now Test, Inside the Scope You Just Wrote (Lab 5 skills)

Using your own OWASP BWA instance as the “demo instance,” and staying strictly inside the scope you drafted in Part 1:

1. Configure Burp as an intercepting proxy and pick one login-driven application on OWASP BWA, exactly as in Lab 5.
2. Capture and record a login request in full (method, headers, cookie, body).
3. Attempt at least one modification to a request (parameter tampering, an ID change, or similar) and record the application's response.
4. Build an endpoint table of at least five requests from Proxy history.
5. Map at least **three** observations to OWASP Top Ten categories this time — one more than Lab 5 required.

If, during testing, you find something that feels like it belongs to a target **outside** the scope you wrote in Part 1 (for instance, infrastructure that isn't part of “the demo instance”), stop, do not test it, and record that decision instead — this is itself a gate check, and documenting a boundary you respected is worth credit.

Part 3 — Write the Report for the Board Member Who Signed

Produce a single report with three sections:

Section A — The Paperwork. Your finished Rules of Engagement and authorization letter from Part 1, as final artifacts, not drafts.

Section B — The Technical Findings. Your Part 2 endpoint table and OWASP Top Ten mappings, written the way a finding is written for someone who has to act on it: what you found, the evidence, and the fix.

Section C — The Judgment Call. One paragraph on the board-member-as-signer problem: does a former-IT board member have the authority the letter needs, and what would you have asked before accepting his signature?

Reflection — Answer Both

1. Compare this assignment to the take-home assignment based on Labs 1–4. That one was almost entirely technical judgment; this one gated the technical work behind a paperwork decision. Which mistake would be easier to walk back afterward — a technical misstep inside a properly scoped test, or a technically perfect test run on a badly scoped engagement? Defend your answer.
 2. The director’s email says “it’s basically the real thing” about the demo instance. In your own words, why does “basically” do a lot of unauthorized work in that sentence — and what question should you have asked before accepting it?
-

Submission Checklist

- ☐ Part 1: Four Gates analysis, 3+ red flags, corrected Rules of Engagement (6 categories), authorization letter (5 elements), engagement type/model justification
- ☐ Part 2: login request capture, one modified-request result, 5+ row endpoint table, 3 OWASP Top Ten mappings (or a documented out-of-scope stop, if that’s what happened)
- ☐ Part 3: three-section report
- ☐ Both reflection answers

Submit as a single PDF.

Grading (suggested — adjust to your rubric)

Component	Weight
Part 1 — Paperwork (completeness and judgment, not just the template filled in)	35%
Part 2 — Technical execution inside scope	30%
Part 3 — Report quality	20%
Reflection answers	15%

A student who correctly identifies a boundary they should not cross in Part 2 — and stops — should score as well as one who found more inside the lines. This assignment grades judgment first and technique second.

Academic Integrity

Your Rules of Engagement, letter, and technical findings should be written in your own words and reflect your own OWASP BWA session. Comparing which red flags you each caught in Part 1 is fine; submitting identical paperwork is not.

This closes the Module 1 assignment sequence. Module 2 assumes you can produce both halves of this work — the scope and the test — without being told which one to do first.